Maturity Assessment Notes Template

Use this consolidated template for capturing notes during a maturity assessment session. Follow the flow below, but skip around as needed during the call.

- Attendees:
- Account:
- Date:
- Follow-ups / Actions:

Pre-Assessment

- Check the instance dashboard in Tableau or the Analytics tab in the Account in Salesforce for telemetry (version, LOC, number of projects).
- Check for support tickets on the account as a fallback.

Basics

If available from telemetry/SIF, fill in prior to the call; otherwise, capture live.

- Lines of Code (LOC)
- Installed version
- DevOps platform(s)
- Other important tools in the DevOps toolchain (legacy CIs, other analysis or testing tools)
- Number of developers/teams in the organisation

Preliminary Questions

- What version of SonarQube is installed? Who is using the tool? How many developers/teams?
- Are many/all projects in the organisation being analysed?
- Is analysis automated as part of CI pipeline execution?
- What DevOps platform(s) are you using (e.g., GitHub)?
- Are you analysing Pull Requests and seeing the results in your DevOps platform?
- Are Quality Gates failing pipelines or blocking merges?
- Who gets notified when a Quality Gate fails?
- Who administers Quality Gates and Quality Profiles?

- Do developers use the SonarQube extension for IDEs? Are they connecting the IDE to the server?
- Outside of developers and teams, who is using Sonar reporting?
- Are you using any security or analysis tools?
    - Speak about SQAS here
- What would you say is the primary language across most of your projects?

Administration

Governance and instance hygiene

- Forced user authentication enabled (Admin > Configuration > Security)?
- **Global permissions**
    - Users vs groups; rationale for assignments
    - Who has:
        - Execute Analysis,
        - Quality Gate/Profile admin,
        - Administer System permissions?
- **Permission templates**
    - In use?
    - Integrated with GitHub for syncing?
    - Project key convention: appropriate and consistent?
- **Marketplace**
    - 3rd party plugins in use?
        - Who installed them, why?
        - Are they truly needed or creating noise?
- **License Manager**: current LOC consumed and threshold reminders

Quality Gates

Enforcement of meaningful standards

- Default Quality Gate
    - Is it Sonar Way?
- For custom gates:
    - Who sets these up?
    - Extending from Sonar Way?
    - Conditions on New Code
    - Are additional criteria meaningful?
    - Too strict? Check projects using the gate and whether they pass/fail due to conditions

    - Large number of custom gates? Consider clean-up
    - Are gate definitions well controlled? Any not used at all?
    - Hierarchy or levels of conditions

Quality Profiles

Governance of rules and impact of updates

- Who sets these up?
- Focus on profiles for the customer's main languages
- Using Sonar Way or inheriting from it?
- If copy/non-inherited profiles exist: how are rules selected? Periodic review?
- Compare with Sonar Way to identify deltas
- Too many profiles? Are they all actively used? Consider clean-up
- Hierarchy or organisation of rules if multiple profiles exist

Projects

Assess activity levels and freshness of data

- Number of projects; LOC count
- Sort by last analysis (oldest first): projects scanned >4 weeks ago? Why?
- Sort by last analysis (newest first): how recent is the most recent scan?
- Sort by size: any huge projects? Is performance acceptable when analysing these?
- Pick a representative active project (popular/well-configured)
    - New Code period/definition: does it make sense?
    - Branches and PRs present? Is PR analysis part of the dev workflow?
    - Activity tab: frequency of analysis; versioning approach
    - Project permissions: using users or groups? Are they meaningful?
    - Quality Gate outcomes: regularly failing? Too strict? Any project-level overrides?

Reporting (Leaders)

Visibility and utilisation of reporting

- Examine Portfolios (selection method, reporting needs)
- If using Portfolios, discuss pattern matching on project keys/names (SQS only)
- Other reporting mechanisms (e.g., custom reporting via Sonar's web API)

Portfolios & Applications

- Are they used? Who creates and maintains them?
- Are report capabilities utilised effectively?

Additional Touch Points

AI usage

- Do they use AI in their process?
    - If so, what AI?
    - How is it used?
- Do they have any initiatives for implementing/expanding AI?
- Are they aware of our AI features?
    - Would there be interest in a demo or enablement session?

Advanced Security

- Are they aware of our SCA features?
- Are there any initiatives for implementing open source security in the dev workflow?
- Which team is responsible for security decisions? Would they be interested in a demo of SCA?
- What tools do they currently use for SCA?
    - How do they use these tools?

Miscellaneous

- Scan duration and performance considerations
- Use of exclusions/inclusions/source settings
- Notifications configuration review